

BAN CƠ YẾU CHÍNH PHỦ
HỌC VIỆN KỸ THUẬT MẬT MÃ



THỰC TẬP DỰ ÁN CÔNG NGHỆ

XÂY DỰNG MÔ HÌNH SOC SỬ DỤNG
WAZUH VÀ SNORT

Ngành: An toàn thông tin

Sinh viên thực hiện:

Nhóm: Người thay đổi thế giới

AT20N0147 – Vũ Văn Thắng (*Nhóm trưởng*)

AT20N0105 – Võ Lê Chí Bảo

AT20N0145 – Lều Thanh Tùng

AT20N0121 – Nguyễn Thanh Hòa

AT20N0129 – Nguyễn Đức Mạnh

Giảng viên hướng dẫn:

Th.s Nguyễn Anh Khôi

TP. Hồ Chí Minh – 2026

LỜI CẢM ƠN

Lời đầu tiên, Nhóm 7 xin gửi lời cảm ơn chân thành và sâu sắc nhất đến Ban Giám hiệu cùng toàn thể quý thầy cô Khoa An toàn thông tin - Học viện kỹ thuật mật mã đã tận tình giảng dạy và truyền đạt những kiến thức nền tảng quý báu trong suốt quá trình chúng em học tập tại trường. Đây là hành trang vững chắc giúp chúng em có đủ cơ sở lý luận và thực tiễn để thực hiện đề án này.

Đặc biệt, chúng em xin gửi lời tri ân sâu sắc đến [Th.S Nguyễn Anh Khôi]. Thầy đã trực tiếp hướng dẫn, định hướng và đưa ra những lời khuyên vô cùng giá trị để nhóm có thể hoàn thiện việc triển khai mô hình SOC, cũng như đi sâu vào việc xây dựng các kịch bản tấn công và hoàn thiện quy trình ứng phó sự cố chuyên nghiệp trên hệ thống. Nhờ sự chỉ bảo tận tình và những phản biện sắc bén của Thầy, đề án của chúng em mới có thể đạt được kết quả như ngày hôm nay.

Bên cạnh đó, chúng em cũng xin cảm ơn gia đình và những người bạn đồng hành (đặc biệt là cả những người bạn dù không học trong khối ngành kỹ thuật nhưng vẫn luôn sẵn sàng lắng nghe và đưa ra những góc nhìn khách quan) đã luôn động viên, tạo điều kiện tốt nhất về tinh thần để chúng em yên tâm tập trung nghiên cứu.

Mặc dù nhóm đã nỗ lực hết sức để hoàn thiện đề án "*Xây dựng mô hình SOC sử dụng Wazuh và Snort*", nhưng do những hạn chế nhất định về mặt thời gian và kinh nghiệm thực tiễn triển khai diện rộng, báo cáo chắc chắn không tránh khỏi những thiếu sót. Chúng em rất mong nhận được sự góp ý, chỉ bảo thêm của thầy để đề án được hoàn thiện hơn, đồng thời giúp nhóm đúc rút thêm nhiều bài học kinh nghiệm cho chặng đường công việc sau này.

Chúng em xin chân thành cảm ơn!

Tóm tắt

Hiện nay, trong kỷ nguyên an ninh mạng thích ứng (*The Era of Adaptive Cybersecurity*), các mối đe dọa trực tiếp đến an toàn thông tin có sự gia tăng mạnh mẽ về mức độ và phạm vi ảnh hưởng. Dữ liệu từ vật lý (tập trung) đến phân tán (số hóa), từ tĩnh (lưu trữ) sang động (luân chuyển/học tập) và từ mục tiêu bị đánh cắp đến vũ khí được cá nhân/tổ chức hóa. Với phạm vi tấn công chuyển đổi cao như trên, SOC (*Security Operations Center*) chuyển từ vị trí hỗ trợ công nghệ thông tin trở thành hạt nhân điều hành của toàn bộ hệ sinh thái giám sát an ninh.

Báo cáo này trình bày quá trình tập trung thiết kế và triển khai một mô hình SOC đa lớp quy mô nhỏ. Mô hình có sự chuyển dịch từ giám sát tập trung (*Centralized Monitoring*) sang giám sát đa tầng (*Layered System Monitoring*), kết hợp nền tảng giám sát máy chủ **Wazuh** với hệ thống phát hiện xâm nhập mạng **Snort** nhằm đồng bộ hóa dữ liệu giám sát từ các tầng. Được triển khai trên môi trường ảo hóa (Homelab) với Wazuh có vị trí trung tâm đóng vai trò thu thập, phân tích và hiển thị cảnh báo và Snort đảm nhiệm chức năng giám sát và phát hiện sự bất thường trên lưu lượng mạng.

Trong quá trình thực nghiệm, việc triển khai các kịch bản tấn công phổ biến như rà soát các cổng mạng, tấn công dò quét (*Brute-force Attack*),... để đánh giá khả năng giám sát của hệ thống đã được nhóm mô phỏng. Kết quả đạt được từ việc giám sát ở cấp độ gói tin từ Snort và các biến động cụ thể trong các tiến trình hệ thống được Wazuh cung cấp đã cho hệ thống sự giám sát và tổng hợp kịch bản tấn công toàn diện. Từ đó chứng minh tính khả thi của việc triển khai mô hình trên ở quy mô nhỏ phục vụ mục đích giám sát và nghiên cứu an toàn thông tin.

Mục lục

Lời cảm ơn	i
Tóm tắt	ii
1 Tổng quan về đề tài và xu hướng	1
1.1 Lý do chọn đề tài	1
1.2 Tổng quan về Trung tâm điều hành an ninh mạng (SOC)	3
1.2.1 Khái niệm SOC	3
1.2.2 Ba trụ cột cốt lõi của SOC	3
1.2.3 Vai trò của SIEM và IDS/IPS trong nền tảng công nghệ SOC	3
1.3 Trung tâm điều hành an toàn thông tin SOC	4
1.3.1 Khái niệm Trung tâm điều hành ATTT SOC	4
1.3.2 Nguyên lý hoạt động của Trung tâm điều hành ATTT SOC	4
1.3.3 Đối tượng và phạm vi giám sát của SOC	5
1.4 Một số hệ thống và nền tảng giám sát ATTT phổ biến	5
1.5 Lợi ích của việc xây dựng Trung tâm điều hành ATTT SOC	5
2 Hệ thống giám sát an toàn thông tin Wazuh và Snort	6
2.1 Giới thiệu tổng quan về Wazuh	6
2.2 Kiến trúc của Wazuh	6
2.3 Phương thức liên lạc và luồng dữ liệu trong Wazuh	7
2.3.1 Liên lạc giữa Wazuh Agent và Wazuh Server	7
2.3.2 Liên lạc giữa Wazuh và Elastic Stack	7
2.3.3 Luồng dữ liệu log trong hệ thống	7
2.4 Các thành phần chính trong hệ thống Wazuh	7
2.4.1 Wazuh Server	7
2.4.2 Wazuh Agent	7
2.4.3 Wazuh Dashboard	8
2.4.4 Elastic Stack (Wazuh Indexer)	8
2.5 Hệ thống phát hiện xâm nhập Snort	8
2.5.1 Giới thiệu về Snort	8

2.5.2	Kiến trúc của Snort	8
2.5.3	Các chế độ hoạt động của Snort	8
2.5.4	Nguyên lý hoạt động của Snort	9
2.6	Luật (Rules) trong hệ thống Wazuh và Snort	9
2.6.1	Các cấp độ cảnh báo của Wazuh	9
2.6.2	Phân loại luật trong Wazuh	9
2.6.3	Cấu trúc luật Snort	9
2.6.4	Ví dụ rule phát hiện tấn công	9
2.7	Khả năng của hệ thống giám sát Wazuh	10
2.7.1	Phân tích bảo mật	10
2.7.2	Phát hiện xâm nhập	10
2.7.3	Phân tích log	10
2.7.4	Giám sát toàn vẹn tệp (File Integrity Monitoring)	10
2.7.5	Phát hiện lỗ hổng	10
2.7.6	Đánh giá cấu hình	10
2.7.7	Ứng phó sự cố (Incident Response)	11
2.8	Kết luận chương 2	11
3	Xây dựng mô hình SOC sử dụng Wazuh và Snort	12
3.1	Cơ sở lý thuyết xây dựng SOC	12
3.2	Thiết kế mô hình SOC đề xuất	13
3.3	Triển khai hệ thống thực nghiệm	14
3.3.1	Môi trường triển khai	14
3.3.2	Cài đặt và cấu hình pfsense	15
3.3.3	Phân hoạch mạng	15
3.3.4	Cài đặt và cấu hình Wazuh	16
3.3.5	Cài đặt và cấu hình Snort	16
3.3.6	Tích hợp Snort với Wazuh	16
3.4	Một số vấn đề phát sinh khi triển khai hệ thống	17
3.4.1	Dữ liệu cảnh báo từ Snort không phân tích được trên Wazuh Dashboard:	17
3.4.2	Mất kết nối giao diện quản trị WebGUI pfSense (Lỗi PHP/Nginx):	17
3.4.3	Máy chủ Wazuh sập nguồn/treo hệ thống do quá tải:	18
3.4.4	Nghẽn cổ chai băng thông (Network Bottleneck) trên pfSense:	18
3.5	Thử nghiệm và đánh giá hệ thống	18
3.5.1	Xây dựng kịch bản tấn công	18
3.5.2	Kịch bản 1: Phát hiện quét cổng	19
3.5.3	Kịch bản 2: Phát hiện brute-force SSH	19

3.5.4 Kịch bản 3: Phát hiện tấn công Web	19
3.6 Kết quả giám sát	19
3.7 Kết luận chương 3	19
Kết luận	20
Hướng phát triển	21
Tài liệu tham khảo	22
A Cấu hình Wazuh	23
B Cấu hình Snort	24
C Rule phát hiện tấn công	25
D Lệnh test tấn công	26

Danh sách hình vẽ

3.1	Mô hình SOC đề xuất	13
-----	-------------------------------	----

Danh sách bảng

Chương 1

Tổng quan về đề tài và xu hướng

1.1 Lý do chọn đề tài

- **Tình hình tấn công mạng hiện nay:** Trong bối cảnh điện toán đám mây phát triển, các mối đe dọa an toàn thông tin gia tăng mạnh mẽ về cả quy mô lẫn mức độ tinh vi. Các cuộc tấn công ngày càng được tự động hóa, diễn ra liên tục và nhắm vào đa dạng mục tiêu trên Internet.
- **Các loại tấn công phổ biến:** Các hệ thống mạng (Cloud, VPS) thường xuyên phải hứng chịu những rủi ro như là: rà quét cổng mạng (Port Scanning) để tìm điểm yếu, tấn công dò quét mật khẩu (Brute-force) vào các dịch vụ quản trị từ xa, và khai thác lỗ hổng ứng dụng web (SQL Injection, XSS)...
- **Ảnh hưởng của các cuộc tấn công mạng:** Sự cố an ninh mạng gây ra hậu quả trực tiếp như gián đoạn dịch vụ (Downtime) và thất thoát dữ liệu nhạy cảm. Điều này làm suy giảm nghiêm trọng uy tín của nhà cung cấp và gây thiệt hại lớn về kinh tế.
- **Một số sự kiện tiêu biểu:** Các báo cáo điều tra chính thức từ các cơ quan chính phủ và tổ chức quốc tế đối với các thảm họa an ninh mạng lớn đều chỉ ra một lỗ hổng chí mạng chung: Sự vắng bóng hoặc thất bại của hệ thống giám sát tập trung và cảnh báo chủ động (hay còn gọi là Trung tâm điều hành an ninh mạng - SOC). Dưới đây là 3 minh chứng điển hình:
 - **Sự kiện tấn công mạng TalkTalk (Vương quốc Anh, 2015):**
 - *Phân tích sự cố:* Công ty viễn thông TalkTalk bị tin tặc tấn công liên tục bằng kỹ thuật SQL Injection rất cơ bản, dẫn đến rò rỉ dữ liệu của hàng trăm ngàn khách hàng.
 - *Nguyên nhân cốt lõi:* Trong biên bản phạt 400.000 Bảng Anh, Văn phòng Ủy viên Thông tin Vương quốc Anh (UK ICO) kết luận TalkTalk đã thất bại trong việc triển khai "*các hoạt động giám sát chủ động (proactive monitoring) để phát hiện lỗ hổng*" [1].

- **Thảm họa rò rỉ dữ liệu Cơ quan Quản lý Nhân sự Mỹ (OPM, 2014-2015):**

- *Phân tích sự cố:* Dữ liệu cá nhân và hồ sơ an ninh của 22 triệu nhân viên chính phủ Mỹ bị đánh cắp. Kẻ tấn công đã lẩn trốn trong hệ thống gần 1 năm trời mà không bị phát hiện.
- *Nguyên nhân cốt lõi:* Báo cáo điều tra của Ủy ban Giám sát Hạ viện Mỹ đã chỉ trích gay gắt OPM vì sự yếu kém trong việc triển khai "*giám sát liên tục (continuous monitoring)*" và hoàn toàn "*mù lòa*" do không nâng cấp các công cụ "*quản lý log (log management)*" [2].

- **Vụ rò rỉ dữ liệu Equifax (Mỹ, 2017):**

- *Phân tích sự cố:* Dữ liệu của hơn 147 triệu khách hàng bị đánh cắp do tin tặc khai thác một lỗ hổng ứng dụng web chưa được vá.
- *Nguyên nhân cốt lõi:* Báo cáo của Hạ viện Mỹ chỉ rõ một chi tiết: Thiết bị giám sát lưu lượng mạng của Equifax đã ngừng hoạt động trong suốt "*19 tháng*" [3] do quên gia hạn chứng chỉ bảo mật. Hệ thống bảo mật hoàn toàn bị mù trước các luồng dữ liệu bị trút ra ngoài.

Kết luận: Từ những bài học trên, có thể thấy "giám sát chủ động", "quản lý log tập trung" và "phát hiện liên tục" chính là 3 trụ cột không thể thiếu để bảo vệ một hệ thống mạng.

Xuất phát từ thực trạng về an toàn thông tin trên, nhóm quyết định lựa chọn đề tài: "**Xây dựng mô hình SOC sử dụng Wazuh và Snort**". Bằng việc kết hợp sức mạnh phát hiện bất thường trên đường truyền mạng (NIDS - Snort) và khả năng giám sát chuyên sâu, phân tích log tại các điểm cuối (HIDS - Wazuh), đề án hướng tới mục tiêu:

1. Xây dựng một kiến trúc giám sát tập trung, xóa bỏ các "điểm mù" trong hệ thống mạng.
2. Hiện thực hóa các kịch bản phát hiện tấn công mạng thực tế.
3. Tự động hóa quy trình ứng phó sự cố (Active Response) để giảm thiểu tối đa thời gian phản ứng trước các rủi ro.

Giải pháp này không chỉ mang lại hiệu quả bảo mật toàn diện mà còn tối ưu hóa về mặt chi phí nhờ ứng dụng các công nghệ mã nguồn mở hàng đầu hiện nay.

1.2 Tổng quan về Trung tâm điều hành an ninh mạng (SOC)

1.2.1 Khái niệm SOC

Trung tâm điều hành an ninh mạng (Security Operations Center - SOC) là một đơn vị tập trung trong tổ chức, chịu trách nhiệm liên tục giám sát, đánh giá và bảo vệ hệ thống công nghệ thông tin (bao gồm mạng, máy chủ, thiết bị đầu cuối và cơ sở dữ liệu) trước các mối đe dọa an ninh mạng. Mục tiêu tối thượng của SOC là phát hiện, phân tích và phản ứng với các sự cố an ninh mạng trong thời gian thực, đảm bảo sự gián đoạn đối với hoạt động kinh doanh ở mức thấp nhất.

1.2.2 Ba trụ cột cốt lõi của SOC

Một hệ thống SOC hoàn chỉnh không chỉ là việc mua sắm phần cứng hay phần mềm, mà là sự kết hợp hài hòa của ba yếu tố (PPT - People, Process, Technology):

- **Con người (People):** Là đội ngũ chuyên gia phân tích an ninh (SOC Analysts), kỹ sư ứng phó sự cố (Incident Responders) và thợ săn mối đe dọa (Threat Hunters). Họ là những người trực tiếp đọc hiểu cảnh báo, phân tích mức độ nghiêm trọng và ra quyết định xử lý.
- **Quy trình (Process):** Các quy chuẩn và kịch bản chuẩn hóa (Playbooks/Runbooks) hướng dẫn đội ngũ SOC phải làm gì khi đối mặt với từng loại tấn công cụ thể. Ví dụ: Quy trình cách ly máy chủ khi nhiễm Ransomware, quy trình báo cáo lỗ hổng.
- **Công nghệ (Technology):** Là hệ sinh thái các công cụ bảo mật hỗ trợ con người thu thập và phân tích dữ liệu. Đây chính là trọng tâm mà đề án này hướng tới. Công nghệ của SOC thường bao gồm các hệ thống phòng thủ bề mặt (Firewall, IPS/IDS) và hạt nhân trung tâm là hệ thống quản lý sự kiện và thông tin bảo mật (SIEM).

1.2.3 Vai trò của SIEM và IDS/IPS trong nền tảng công nghệ SOC

Để SOC có thể "nhìn thấy" các mối đe dọa, hệ thống công nghệ cần được xây dựng dựa trên các cảm biến (sensors) và bộ não phân tích tập trung:

- **Hệ thống phát hiện xâm nhập (IDS/IPS):** Đóng vai trò như những "chiếc camera an ninh" đặt tại các cửa ngõ mạng. Chúng liên tục bắt gói tin (packet capture) và so khớp với các dấu hiệu nhận dạng (signatures) để phát hiện các truy cập trái phép. Snort là một trong những NIDS (Network-based IDS) mã nguồn mở tiêu biểu nhất đảm nhiệm vai trò này.
- **Hệ thống SIEM (Security Information and Event Management):** Được ví như "bộ não" của SOC. SIEM thu thập log từ hàng ngàn thiết bị khác nhau (từ Router, Firewall, máy chủ Windows/Linux cho đến thiết bị IDS như Snort). Sau đó, SIEM chuẩn hóa và tương quan (correlation) các log này để tìm ra chuỗi hành vi bất thường, từ đó phát ra cảnh báo cho SOC Analysts. Trong đề án này, Wazuh được sử dụng như một nền tảng SIEM và XDR (Extended Detection and Response) kết hợp.

Như vậy, việc xây dựng mô hình SOC về bản chất là việc tích hợp các công nghệ thu thập dữ liệu mạng (như Snort) và công nghệ phân tích điểm cuối (như Wazuh) vào một quy trình giám sát tập trung. Sự kết hợp này tạo ra khả năng hiển thị (visibility) toàn diện, giúp tổ chức chủ động phòng thủ trước các rủi ro.

1.3 Trung tâm điều hành an toàn thông tin SOC

1.3.1 Khái niệm Trung tâm điều hành ATTT SOC

SOC là một hệ thống điều phối tiêu chuẩn, kết hợp bắt buộc giữa ba yếu tố: Con người, Quy trình và Công nghệ. SOC hoạt động như một trạm kiểm soát trung tâm, liên tục thu thập và phân tích dữ liệu để bảo vệ tài sản thông tin.

1.3.2 Nguyên lý hoạt động của Trung tâm điều hành ATTT SOC

- **Thu thập log:** Dồn toàn bộ dữ liệu nhật ký phân tán từ tường lửa, thiết bị mạng và hệ điều hành về một đầu nơi.
- **Phân tích dữ liệu:** Chuẩn hóa dữ liệu thô và trích xuất các thông tin cốt lõi (IP nguồn, tài khoản truy cập).
- **Phát hiện tấn công:** Tự động đối chiếu dữ liệu với các tập luật (Rules) để phát hiện ngay lập tức các hành vi vi phạm.
- **Cảnh báo và phản ứng sự cố:** Cảnh báo trực quan và hỗ trợ ngăn chặn kịp thời các kết nối độc hại.

1.3.3 Đối tượng và phạm vi giám sát của SOC

- **Máy chủ:** Cụm máy chủ ảo hóa vật lý và các máy ảo cung cấp dịch vụ.
- **Thiết bị mạng:** Hệ thống định tuyến và tường lửa biên.
- **Hệ điều hành:** Tiến trình hệ thống và tính toàn vẹn của tệp tin.
- **Ứng dụng:** Web Server, hệ quản trị cơ sở dữ liệu và các nền tảng ứng dụng đang vận hành.
- **Lưu lượng mạng:** Luồng dữ liệu giao tiếp với Internet và luồng nội bộ giữa các máy chủ.

1.4 Một số hệ thống và nền tảng giám sát ATTT phổ biến

Bên cạnh các giải pháp thương mại đắt đỏ, các nền tảng mã nguồn mở đang là tiêu chuẩn chung cho các hạ tầng tự lưu trữ (self-hosted). Việc triển khai kết hợp Wazuh (SIEM/HIDS) và Snort (NIDS) cung cấp đầy đủ các chức năng cốt lõi của một SOC chuyên nghiệp, đáp ứng hoàn toàn yêu cầu giám sát thực tiễn mà không bị ràng buộc về chi phí.

1.5 Lợi ích của việc xây dựng Trung tâm điều hành ATTT SOC

Tóm lại, SOC là thành phần hạ tầng không thể thiếu. Việc tích hợp SOC giúp quản trị viên nắm giữ hoàn toàn quyền kiểm soát hệ thống, chuyển từ trạng thái bị động chịu trận sang chủ động phát hiện và dập tắt các chuỗi tấn công ngay từ trong trứng nước.

Chương 2

Hệ thống giám sát an toàn thông tin Wazuh và Snort

2.1 Giới thiệu tổng quan về Wazuh

Wazuh là một nền tảng mã nguồn mở miễn phí, cung cấp giải pháp giám sát an ninh, phát hiện các mối đe dọa (Threat Detection), giám sát tính toàn vẹn và phản ứng sự cố (Incident Response). Bằng cách kết hợp khả năng của Hệ thống quản lý sự kiện và thông tin bảo mật (SIEM) cùng Phát hiện và phản hồi điểm cuối (XDR), Wazuh giúp thu thập, tổng hợp, phân tích dữ liệu log từ nhiều nguồn khác nhau trên toàn bộ hệ thống mạng để phát hiện các dấu hiệu tấn công mạng từ sớm.

2.2 Kiến trúc của Wazuh

Kiến trúc của Wazuh được thiết kế theo mô hình phân tán, cho phép mở rộng linh hoạt tùy theo quy mô của hạ tầng mạng. Các thành phần cơ bản bao gồm:

- **Wazuh Server:** Trung tâm phân tích và xử lý dữ liệu.
- **Wazuh Agent:** Tác nhân thu thập dữ liệu cài đặt trên các máy trạm/máy chủ.
- **Wazuh Dashboard:** Giao diện quản trị và trực quan hóa dữ liệu.
- **Wazuh Indexer (Elastic Stack / OpenSearch):** Công cụ lưu trữ và tìm kiếm log tốc độ cao.

2.3 Phương thức liên lạc và luồng dữ liệu trong Wazuh

2.3.1 Liên lạc giữa Wazuh Agent và Wazuh Server

Wazuh Agent giao tiếp với Server chủ yếu qua cổng 1514 (TCP/UDP) bằng giao thức định tuyến thông điệp độc quyền, được mã hóa bằng AES để đảm bảo an toàn. Quá trình đăng ký ban đầu (Enrollment) thường diễn ra qua cổng 1515 để cấp phát chứng chỉ xác thực.

2.3.2 Liên lạc giữa Wazuh và Elastic Stack

Wazuh Server sử dụng Filebeat (hoặc module tương đương) để gửi các cảnh báo (alerts) và log đã qua phân tích đến Wazuh Indexer (Elastic Stack) qua cổng 9200 (REST API). Kết nối này được bảo mật bằng TLS để chống nghe lén dữ liệu.

2.3.3 Luồng dữ liệu log trong hệ thống

Dữ liệu sinh ra từ thiết bị (Log OS, Syslog từ Firewall, NIDS) được Agent thu thập → Đẩy về Wazuh Server → Server giải mã (Decode), phân tích và so khớp với Luật (Rule) → Sinh ra cảnh báo nếu khớp → Đẩy cảnh báo vào Indexer → Hiển thị trên Dashboard.

2.4 Các thành phần chính trong hệ thống Wazuh

2.4.1 Wazuh Server

Thành phần cốt lõi chạy dịch vụ **wazuh-manager**. Nhiệm vụ chính là phân tích dữ liệu nhận được từ các Agent, giải mã định dạng log, và so khớp với bộ quy tắc tập trung để phát hiện các hành vi bất thường, vi phạm chính sách hoặc mã độc. Server cũng chịu trách nhiệm kích hoạt các kịch bản phản hồi tự động (Active Response).

2.4.2 Wazuh Agent

Là phần mềm nhẹ, tiêu tốn ít tài nguyên được cài đặt trực tiếp trên các hệ điều hành (Windows, Linux, macOS). Agent liên tục giám sát hệ thống, đọc các tập tin log theo thời gian thực, kiểm tra tính toàn vẹn của tập tin (FIM) và thu thập dữ liệu cấu hình để gửi về Server.

2.4.3 Wazuh Dashboard

Giao diện người dùng nền web, giúp quản trị viên trực quan hóa các sự kiện bảo mật. Nó cung cấp các biểu đồ, báo cáo chi tiết về tình trạng an ninh của hệ thống, giúp đẩy nhanh quá trình điều tra số (Forensics) và giám sát tập trung.

2.4.4 Elastic Stack (Wazuh Indexer)

Hệ thống lưu trữ dữ liệu dạng văn bản phân tán, cho phép lập chỉ mục toàn văn bản với khả năng tìm kiếm cực nhanh. Dữ liệu cảnh báo được lưu trữ tại đây để phục vụ cho việc truy xuất, truy vấn lịch sử và lập báo cáo.

2.5 Hệ thống phát hiện xâm nhập Snort

2.5.1 Giới thiệu về Snort

Snort là một hệ thống phát hiện và ngăn chặn xâm nhập mạng (NIDS/NIPS) mã nguồn mở hàng đầu. Snort có khả năng phân tích lưu lượng truy cập mạng theo thời gian thực và ghi log các gói tin trên mạng IP, đóng vai trò như một lớp phòng thủ vòng ngoài (Network-level) kết hợp với bảo mật điểm cuối của Wazuh.

2.5.2 Kiến trúc của Snort

Snort bao gồm các thành phần: Packet Decoder (Giải mã gói tin), Preprocessors (Tiền xử lý), Detection Engine (Động cơ phát hiện), và Logging/Alerting System (Hệ thống ghi log và cảnh báo).

2.5.3 Các chế độ hoạt động của Snort

Snort thường hoạt động ở 3 chế độ chính:

- **Sniffer Mode:** Bắt và hiển thị gói tin trực tiếp lên màn hình.
- **Packet Logger Mode:** Bắt và lưu gói tin vào ổ đĩa để phân tích sau (thường lưu dạng pcap).
- **NIDS Mode:** Áp dụng luật để phát hiện xâm nhập và sinh cảnh báo khi có tấn công.

2.5.4 Nguyên lý hoạt động của Snort

- **Phân tích gói tin:** Snort chặn bắt giao thông mạng đi qua giao diện (interface) được giám sát.
- **So khớp chữ ký tấn công:** Động cơ phát hiện sẽ so sánh nội dung gói tin với bộ luật (ruleset) đã được định nghĩa sẵn.
- **Phát hiện bất thường:** Nếu gói tin khớp với mẫu của một cuộc tấn công (ví dụ: DoS, Port Scan), Snort sẽ kích hoạt hành động tương ứng (Alert, Drop, Pass).

2.6 Luật (Rules) trong hệ thống Wazuh và Snort

2.6.1 Các cấp độ cảnh báo của Wazuh

Wazuh phân loại cảnh báo theo các cấp độ (Level) từ 0 đến 15. Cấp độ 0-2 thường là các thông tin hệ thống bình thường. Từ cấp 3 trở lên bắt đầu được ghi nhận (Alert). Cấp độ 12-15 biểu thị các cuộc tấn công cực kỳ nghiêm trọng hoặc sự cố hệ thống diện rộng cần xử lý ngay lập tức.

2.6.2 Phân loại luật trong Wazuh

Luật của Wazuh được chia làm nhiều nhóm, tiêu biểu như luật giám sát hệ điều hành (Windows/Linux), luật ứng dụng (Web server, Database), và luật do người dùng tự định nghĩa (Custom rules) để phát hiện các kịch bản tấn công cụ thể trong mô hình SOC.

2.6.3 Cấu trúc luật Snort

Một luật Snort chuẩn gồm 2 phần:

- **Rule Header:** Xác định hành động (alert, log, drop), giao thức (TCP/UDP/ICMP), địa chỉ IP và Cổng (Port) của nguồn và đích.
- **Rule Options:** Chứa thông báo cảnh báo và các dấu hiệu nhận dạng (signature) để kiểm tra tải trọng (payload) của gói tin.

2.6.4 Ví dụ rule phát hiện tấn công

Ví dụ một rule Snort đơn giản phát hiện quét cổng SSH:

```
1 alert tcp any any -> $HOME_NET 22 (msg:"Phieu_trinh_SSH_Brute
   _Force"; flags:S; threshold:type both, track by_src, count
   5, seconds 60; sid:100001; rev:1;)
```

2.7 Khả năng của hệ thống giám sát Wazuh

2.7.1 Phân tích bảo mật

Wazuh thu thập, tổng hợp và phân tích dữ liệu bảo mật từ các điểm cuối, giúp phát hiện các cấu hình ẩn, hành vi mờ ám của phần mềm độc hại.

2.7.2 Phát hiện xâm nhập

Động cơ phân tích của Wazuh sử dụng bộ quy tắc để nhận diện các Indicator of Compromise (IoC), phát hiện các nỗ lực xâm nhập trái phép, leo thang đặc quyền hoặc khai thác lỗ hổng đã biết.

2.7.3 Phân tích log

Hệ thống tự động chuẩn hóa log từ nhiều định dạng khác nhau (syslog, Windows event logs, firewall logs) về một định dạng chung, giúp dễ dàng truy vấn và tạo các biểu đồ trực quan.

2.7.4 Giám sát toàn vẹn tệp (File Integrity Monitoring)

Module FIM giám sát hệ thống tệp tin, nhận biết sự thay đổi về quyền, nội dung, hay thuộc tính của các tệp tin quan trọng (ví dụ: file cấu hình `/etc` trên Linux), giúp phát hiện rootkit hoặc mã độc tống tiền (Ransomware).

2.7.5 Phát hiện lỗ hổng

Wazuh so khớp danh sách các ứng dụng được cài đặt trên tác nhân (Agent) với cơ sở dữ liệu lỗ hổng chung (CVE) để đánh giá và cảnh báo các phần mềm đang dính lỗi bảo mật.

2.7.6 Đánh giá cấu hình

Wazuh liên tục quét hệ thống để đảm bảo các thiết bị tuân thủ các tiêu chuẩn cấu hình bảo mật chuẩn như CIS (Center for Internet Security) hoặc PCI DSS.

2.7.7 Ứng phó sự cố (Incident Response)

Đây là một trong những tính năng mạnh mẽ nhất trong việc vận hành SOC. Thông qua module Active Response, khi phát hiện các cuộc tấn công (ví dụ: Brute Force SSH, Malware), Wazuh có thể tự động thực thi các tập lệnh trên tác nhân để chặn IP trên tường lửa cục bộ, vô hiệu hóa tài khoản, hoặc cách ly hệ thống khỏi mạng nhằm ngăn chặn thiệt hại lan rộng.

2.8 Kết luận chương 2

Nhìn chung, sự kết hợp giữa Wazuh và Snort tạo ra một hệ thống SOC toàn diện. Trong khi Snort đóng vai trò kiểm soát lưu lượng và phát hiện các nỗ lực tấn công ở cấp độ mạng (Network-based), thì Wazuh đi sâu vào giám sát chi tiết các hành vi ở cấp độ điểm cuối (Host-based), đồng thời cung cấp khả năng tự động ứng phó sự cố chuyên nghiệp. Việc kết hợp cả hai công cụ này mang lại bức tranh toàn cảnh, giúp đội ngũ an toàn thông tin dễ dàng theo dõi, phát hiện và phản ứng kịp thời trước các mối đe dọa mạng.

Chương 3

Xây dựng mô hình SOC sử dụng Wazuh và Snort

3.1 Cơ sở lý thuyết xây dựng SOC

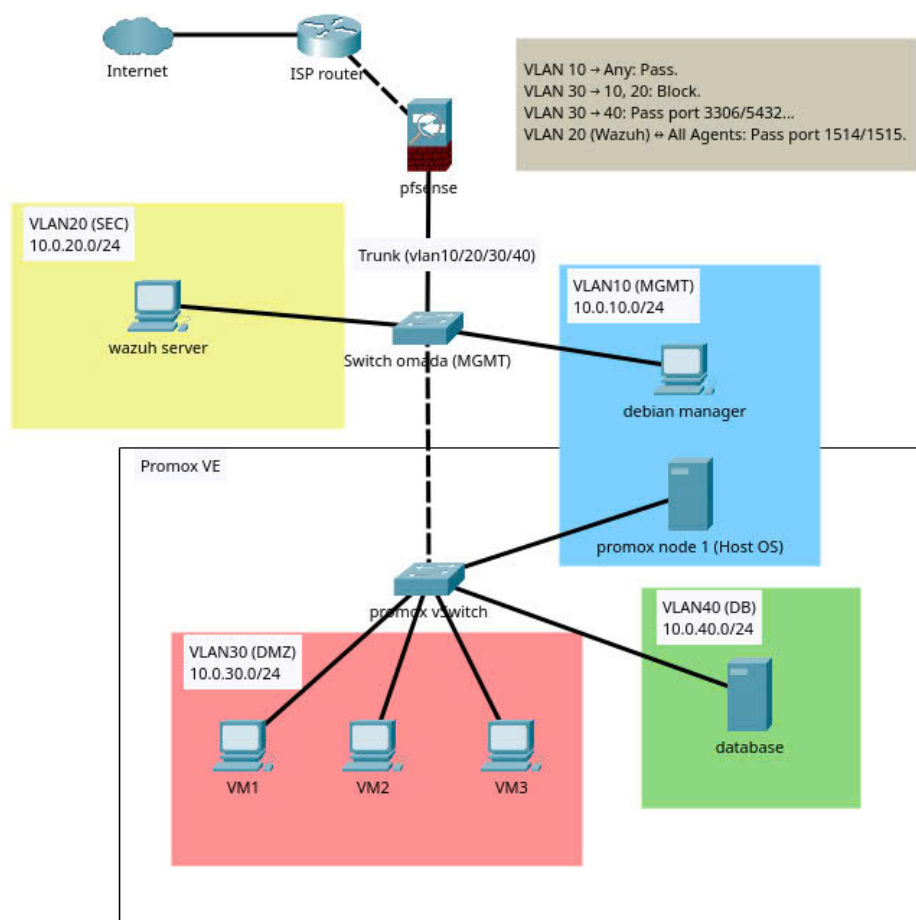
Trong dự án này, mô hình Trung tâm điều hành an toàn thông tin (SOC) được thiết kế dựa trên nguyên lý phòng thủ theo chiều sâu (Defense in Depth). Thay vì chỉ dùng một công cụ bảo vệ duy nhất ở một vị trí, hệ thống kết hợp giám sát ở nhiều lớp khác nhau để hỗ trợ và bù trừ cho nhau. Cơ sở lý thuyết của mô hình tập trung vào ba thành phần cốt lõi:

- **Giám sát lưu lượng mạng (Network-based Monitoring):** Đây là lớp phòng thủ vòng ngoài. Mọi kết nối từ Internet muốn đi vào các máy ảo dịch vụ (nằm ở vùng DMZ) đều bắt buộc phải đi qua Gateway. Bằng cách đặt hệ thống Snort ngay tại tường lửa pfSense, hệ thống có thể kiểm soát toàn bộ gói tin mạng. Snort đóng vai trò gác cổng, dùng các rules có sẵn để phát hiện và cảnh báo sớm các hành vi tấn công từ xa, ví dụ như rà quét cổng (port scanning) hay chen mã độc vào gói tin web.
- **Giám sát điểm cuối (Host-based Monitoring):** Lớp bảo vệ vòng trong được đặt trực tiếp trên các máy ảo cung cấp dịch vụ. Trong thực tế, kẻ tấn công có thể dùng các kỹ thuật mã hóa để lách qua Snort. Do đó, Wazuh Agent được cài thẳng vào các máy để giám sát từ bên trong hệ điều hành. Agent này liên tục đọc log hệ thống (như `auth.log`, `syslog`), theo dõi sự thay đổi của các file quan trọng và cảnh báo ngay khi có kẻ cố gắng dò mật khẩu (brute-force) hay thay đổi cấu hình máy.
- **Quản lý và phân tích log tập trung (Centralized SIEM):** Một hệ thống giám sát sẽ không hiệu quả nếu log bị phân tán rải rác ở nhiều máy khác nhau. Do đó, Wazuh Server được sử dụng làm hệ thống quản lý trung tâm (SIEM). Nó làm nhiệm vụ thu gom cả cảnh báo mạng từ Snort (đẩy về qua cổng Syslog) và cảnh báo hệ thống từ các Wazuh Agent. Toàn bộ dữ liệu này được phân tích và hiển thị chung trên một giao diện thống nhất (Wazuh Dashboard). Nhờ vậy, quản trị viên có thể dễ dàng kiểm soát toàn bộ hệ thống: từ lúc kẻ tấn

công kiểm tra, quét mạng bên ngoài, cho đến khi chúng cố gắng xâm nhập vào bên trong máy chủ.

Việc kết hợp giữa Snort (mạng) và Wazuh (máy chủ) tạo ra một hệ thống giám sát chéo toàn diện, phù hợp với kiến trúc ảo hóa phân chia VLAN đang được triển khai thực nghiệm.

3.2 Thiết kế mô hình SOC đề xuất



Hình 3.1: Mô hình SOC đề xuất

3.3 Triển khai hệ thống thực nghiệm

3.3.1 Môi trường triển khai

Môi trường thực nghiệm được thiết kế và phân hoạch mạng (VLAN) thông qua pfSense và Switch Omada, kết hợp giữa các máy chủ vật lý và môi trường ảo hóa nhằm tối ưu cho việc cung cấp dịch vụ và đảm bảo an toàn, cô lập hệ thống giám sát:

- **Lớp Gateway (Network & Routing):** Sử dụng **pfSense** làm Firewall và định tuyến chính kết nối với ISP Router. pfSense quản lý đường Trunking dẫn xuống Switch vật lý (Switch Omada – MGMT), từ đó phân chia hệ thống thành 4 VLAN riêng biệt kết hợp với các chính sách kiểm soát truy cập (Access Control).
- **Lớp Thiết bị Vật lý (Physical Hosts):** Các thành phần cốt lõi và quản trị được tách rời hoàn toàn khỏi môi trường ảo hóa cấp dịch vụ:
 - **Pfsense:** Thuộc VLAN 10, kết nối trực tiếp vào Switch Omada. Làm tường lửa (Firewall) và định tuyến chính cho toàn bộ hệ thống. Tại đây, hệ thống phát hiện xâm nhập Snort được tích hợp trực tiếp để lắng nghe và phân tích toàn bộ lưu lượng mạng (traffic) từ Internet hướng vào vùng dịch vụ.
 - **Wazuh Server:** Nằm độc lập tại VLAN 20 (SEC), kết nối trực tiếp vào Switch Omada. Dashboard quản lý hệ thống, log từ các nguồn đổ về. Đảm bảo tài nguyên xử lý log không bị ảnh hưởng bởi các dịch vụ ảo hóa.
 - **Debian Manager:** Máy quản trị nằm tại VLAN 10 (MGMT), cài đặt tailscale VPN để làm điểm tựa truy cập dành cho quản trị viên từ ngoài internet.
 - **Proxmox Node 1 (Host OS):** Máy chủ vật lý chạy nền tảng ảo hóa Proxmox VE, IP quản lý nằm tại VLAN 10.
- **Lớp Ảo hóa và Dịch vụ (Virtual Machines – Proxmox VE):** Sử dụng vSwitch (proxmox vswitch) để kết nối mạng cho các phân vùng dịch vụ. Khả năng cung cấp máy ảo của hệ thống linh hoạt và có thể mở rộng tùy thuộc vào tài nguyên phần cứng, trong đó gồm:
 - **Cụm máy chủ cung cấp dịch vụ (VLAN 30 - DMZ):** Là nơi khởi tạo các máy ảo (trong sơ đồ minh họa đại diện bởi VM1, VM2, VM3)

đóng vai trò là các Server tiếp xúc trực tiếp với Internet để phục vụ người dùng cuối

- **Cụm máy chủ Cơ sở dữ liệu (VLAN 40 - DB):** Các máy ảo đóng vai trò lưu trữ dữ liệu Backend (được minh họa bằng máy database) được đặt trong một vùng mạng hoàn toàn tách biệt. Các máy ảo này cung cấp dịch vụ lưu trữ cho cụm DMZ và chỉ cho phép truy xuất thông qua các cổng dịch vụ cụ thể (như 3306 đối với MySQL, 5432 đối với PostgreSQL,...).

3.3.2 Cài đặt và cấu hình pfsense

pfSense được triển khai đóng vai trò là Gateway kết nối ra Internet, đồng thời là tường lửa biên và thiết bị định tuyến trung tâm. Việc cấu hình tập trung vào kiểm soát luồng giao thông mạng (Traffic Routing) và thiết lập giao diện mạng:

- **Cấu hình Interface:** Giao diện WAN được cấu hình nhận IP từ ISP Router để giao tiếp với Internet. Sử dụng mô hình **Double NAT** nhằm giữ khả năng phát mạng của router ISP, không cần quay PPPoE và không làm ảnh hưởng tới cấu hình cơ bản của mạng gốc. Giao diện LAN được thiết lập chế độ Trunking kết nối trực tiếp xuống Switch Omada.
- **Cấu hình Firewall Rules:** Thiết lập các chính sách NAT cho phép máy ảo ở DMZ ra ngoài Internet, đồng thời cấu hình Port Forwarding để đẩy dịch vụ Web/App từ DMZ ra mạng ngoài.

3.3.3 Phân hoạch mạng

Để đáp ứng yêu cầu cô lập dịch vụ và bảo vệ hệ thống quản trị, pfSense và Switch Omada chia hệ thống thành 4 phân vùng VLAN kết hợp với các chính sách Access Control.

- **VLAN 10 (MGMT – 10.0.10.0/24):** Vùng quản trị, có toàn quyền truy cập đến các vùng khác (Pass Any).
- **VLAN 20 (SEC – 10.0.20.0/24):** Vùng an ninh giám sát. Cho phép toàn bộ Agent từ các vùng khác kết nối đến qua cổng 1514/1515.
- **VLAN 30 (DMZ – 10.0.30.0/24):** Vùng cung cấp dịch vụ ra ngoài (cloud, VPS, web hosting, database, storage,...) Bị chặn hoàn toàn quyền truy cập ngược về vùng Quản trị (VLAN 10), vùng An ninh (VLAN 20) và chặn tương tác với máy khác để chống leo thang đặc quyền.

- **VLAN 40** (DB – 10.0.40.0/24): Vùng cơ sở dữ liệu. Vùng DMZ chỉ được phép truy cập vào vùng này qua các port dịch vụ DB cụ thể (3306, 5432).

3.3.4 Cài đặt và cấu hình Wazuh

Hệ thống Wazuh được chia làm hai thành phần chính với quá trình triển khai tương ứng:

- **Triển khai Wazuh Server:** Máy chủ Wazuh được đặt tại vùng VLAN 20. Quá trình cấu hình bao gồm việc thiết lập IP tĩnh (10.0.20.x) và khởi chạy các dịch vụ cốt lõi: Wazuh indexer (lưu trữ dữ liệu), Wazuh server (phân tích) và Wazuh dashboard.
- **Triển khai Wazuh Agent:** Tiến hành cài đặt Agent lên các máy ảo mục tiêu tại DMZ (VLAN 30) và DB (VLAN 40). Tập ossec.conf trên các máy trạm được cấu hình để trở về IP của Wazuh Manager. Sau khi xác thực qua cổng 1515, Agent bắt đầu giám sát tính toàn vẹn của tệp (FIM) và đẩy log hệ thống về máy chủ qua cổng 1514.

3.3.5 Cài đặt và cấu hình Snort

Snort được triển khai như một NIDS (Network Intrusion Detection System), tích hợp trực tiếp trên Firewall pfSense:

- **Cài đặt và Gắn Interface:** Cài đặt qua Package Manager của pfSense. Dịch vụ lắng nghe trực tiếp trên interface Trunking để kiểm soát toàn bộ gói tin đi vào vùng dịch vụ (DMZ).
- **Cập nhật Rulesets:** Kích hoạt tính năng tự động cập nhật các bộ luật từ Snort VRT và Emerging Threats. Ngoài ra lựa chọn bật thêm các nhóm luật liên quan đến rà quét cổng (Port Scanning), tấn công ứng dụng Web (SQLi, XSS) và Brute-force để phù hợp với môi trường dịch vụ đang cung cấp.

3.3.6 Tích hợp Snort với Wazuh

Để tăng tính tập trung của hệ thống SOC, cảnh báo mạng từ Snort cần được đồng bộ về Wazuh:

- **Cấu hình đẩy log trên pfSense:** Thiết lập dịch vụ Syslog trên pfSense, cài đặt chuyển tiếp các cảnh báo từ file snort.alert đến địa chỉ IP của Wazuh Manager tại VLAN 20 thông qua giao thức UDP (Cổng 514).

- **Cấu hình tiếp nhận và phân tích trên Wazuh:** Chỉnh sửa tệp cấu hình của Wazuh Manager để mở cổng 514 tiếp nhận luồng Syslog. Sử dụng các Decoders và Rules có sẵn, Wazuh tự động phân tách dữ liệu (IP nguồn/đích, mã cảnh báo) và biểu diễn trực quan trên Dashboard.

3.4 Một số vấn đề phát sinh khi triển khai hệ thống

3.4.1 Dữ liệu cảnh báo từ Snort không phân tích được trên Wazuh Dashboard:

- **Vấn đề:** pfSense đã chuyển tiếp (forward) log Syslog thành công qua cổng 514, nhưng trên Wazuh Dashboard không hiển thị được các trường dữ liệu chi tiết như IP nguồn, IP đích hay tên cảnh báo.
- **Nguyên nhân:** Định dạng Syslog mặc định đẩy ra từ pfSense có tiền tố (prefix) không khớp hoàn toàn với bộ giải mã (Decoder) mặc định của Wazuh dành cho Snort.
- **Khắc phục:** Cấu hình lại dịch vụ đẩy log trên pfSense để gửi log dưới dạng định dạng chuẩn của Snort (Snort alert format), hoặc tạo một Decoder tùy chỉnh (Custom Decoder) trên Wazuh Server để biểu thức chính quy (Regex) bắt đúng các trường dữ liệu từ log pfSense đẩy về.

3.4.2 Mất kết nối giao diện quản trị WebGUI pfSense (Lỗi PHP/Nginx):

- **Vấn đề:** Khi truy cập vào giao diện web của pfSense, trình duyệt báo lỗi "Not Found" hoặc "502 Bad Gateway", các dịch vụ định tuyến vẫn chạy nhưng không thể quản trị do tiến trình PHP bị ngắt.
- **Nguyên nhân:** Do sử dụng bộ chuyển đổi USB sang LAN (USB-to-RJ45) chất lượng kém để mở rộng cổng mạng cho máy vật lý. Thiết bị này hoạt động không ổn định, gây mất gói tin liên tục ở tầng vật lý khiến hệ thống bị treo tiến trình WebGUI.
- **Khắc phục:** Thay thế bằng đầu chuyển đổi USB-LAN chất lượng tốt hơn, đồng thời tắt bớt các Widget giám sát thời gian thực (Traffic Graphs, System Info) trên Dashboard của pfSense để giảm tải cho dịch vụ PHP-FPM.

3.4.3 Máy chủ Wazuh sập nguồn/treo hệ thống do quá tải:

- **Vấn đề:** Dịch vụ Wazuh Manager đột ngột dừng hoạt động và không thể khởi động lại.
- **Nguyên nhân:** Kiến trúc của Wazuh (đặc biệt là thành phần Wazuh Indexer/Elasticsearch) đòi hỏi tài nguyên RAM và CPU cực kỳ lớn để xử lý dữ liệu. Cấu hình mặc định vượt quá khả năng đáp ứng của máy chủ vật lý đang sử dụng.
- **Khắc phục:** Tiến hành tối ưu hóa lại hệ thống. Bóp bớt yêu cầu hiệu năng bằng cách giới hạn kích thước bộ nhớ của Indexer và vô hiệu hóa các module không thực sự cần thiết để hệ thống chạy ổn định trên tài nguyên giới hạn.

3.4.4 Nghẽn cổ chai băng thông (Network Bottleneck) trên pfSense:

- **Vấn đề:** Tốc độ mạng nội bộ và truy cập Internet đi qua Gateway rất chậm, ảnh hưởng đến toàn bộ hệ thống.
- **Nguyên nhân:** Kiểm tra phần cứng phát hiện cổng USB trên máy vật lý dùng để cắm card mạng LAN mở rộng cho pfSense chỉ hỗ trợ chuẩn USB 2.0 (băng thông tối đa lý thuyết thấp), không đủ sức gánh lưu lượng định tuyến của toàn hệ thống.
- **Khắc phục:** Thay đổi thiết kế triển khai. Tráo đổi vai trò giữa hai máy vật lý: chuyển Wazuh Server sang cài trên máy có cổng USB 2.0 (do Wazuh chỉ nhận log, không yêu cầu băng thông mạng quá lớn), và cài đặt lại pfSense sang máy trước đó cài wazuh do có cổng USB 3.0. Điều này giải quyết triệt để tình trạng nghẽn băng thông.

3.5 Thử nghiệm và đánh giá hệ thống

3.5.1 Xây dựng kịch bản tấn công

Để đánh giá chính xác khả năng phản ứng của mô hình SOC, ba kịch bản tấn công phổ biến sẽ được mô phỏng nhắm thẳng vào các máy ảo mục tiêu đang chạy trên Proxmox:

- **Port Scanning bằng Nmap:** Sử dụng một máy trạm đóng vai trò Kẻ tấn công (Attacker) chạy lệnh Nmap để dò quét các cổng dịch vụ đang mở trên

máy chủ Ubuntu/Windows. Mục tiêu là kiểm tra xem luật (rule) của Snort tại Gateway có phát hiện và cảnh báo được hành vi quét TCP SYN/UDP hàng loạt này hay không.

- **Tấn công dò mật khẩu (Brute-force SSH):** Attacker sử dụng công cụ **Hydra** hoặc **Medusa** để liên tục thử tổ hợp tài khoản/mật khẩu vào cổng 22 (SSH) của máy Ubuntu. Kịch bản này nhằm đánh giá khả năng của Wazuh Agent trong việc ghi nhận lượng lớn log đăng nhập thất bại từ `auth.log` và kích hoạt cảnh báo mức độ cao trên Wazuh Dashboard.
- **Tấn công ứng dụng Web (Web Attack):** Máy ảo Ubuntu đóng vai trò là Web Host sẽ chạy một ứng dụng web có chứa lỗ hổng. Attacker tiến hành chèn mã độc (SQL Injection hoặc XSS) vào các form nhập liệu. Kịch bản này sẽ kiểm chứng sự phối hợp giữa hai hệ thống: Snort bắt được các payload độc hại chứa mã SQL/XSS trong gói tin HTTP, đồng thời Wazuh ghi nhận được sự bất thường trong log của Web Server (Apache/Nginx).
- Port Scanning (Nmap)
- Brute-force SSH
- Web attack

3.5.2 Kịch bản 1: Phát hiện quét cổng

3.5.3 Kịch bản 2: Phát hiện brute-force SSH

3.5.4 Kịch bản 3: Phát hiện tấn công Web

3.6 Kết quả giám sát

3.7 Kết luận chương 3

Kết luận

- Tổng kết kết quả đạt được
- Đánh giá hiệu quả hệ thống
- Những hạn chế của mô hình

Hướng phát triển

- Tích hợp thêm hệ thống SIEM
- Tự động phản ứng sự cố
- Ứng dụng Machine Learning trong phát hiện tấn công

Tài liệu tham khảo

- [1] UK Information Commissioner's Office (ICO). (2016). *TalkTalk cyber attack – how the ICO's investigation unfolded*. Truy cập từ: <https://ico.org.uk/about-the-ico/media-centre/talktalk-cyber-attack-how-the-ico-investigation-unfolded/>
- [2] House Oversight and Government Reform Committee. (2016). *The OPM Data Breach: How the Government Jeopardized Our National Security for More than a Generation*. Truy cập từ: <https://krebsonsecurity.com/2016/09/congressional-report-slams-opm-on-data-breach/>
- [3] House of Representatives. (2018). *The Equifax Data Breach - Majority Staff Report*. Truy cập từ: <https://oversight.house.gov/wp-content/uploads/2018/12/Equifax-Report.pdf>

Phụ lục A

Cấu hình Wazuh

Listing A.1: ossec.conf – Wazuh agent configuration example

```
1 <ossec_config>
2   <client>
3     <server>
4       <address>WAZUH_SERVER_IP</address>
5       <port>1514</port>
6       <protocol>tcp</protocol>
7     </server>
8   </client>
9 </ossec_config>
```

Phụ lục B

Cấu hình Snort

Listing B.1: snort.conf – Snort configuration example

```
1 # Network variables
2 var HOME_NET 192.168.1.0/24
3 var EXTERNAL_NET !$HOME_NET
4
5 # Include rules
6 include $RULE_PATH/local.rules
```


Phụ lục C

Rule phát hiện tấn công

Listing C.1: local.rules – Custom Snort rules

```
1 # Detect port scan
2 alert tcp any any -> $HOME_NET any \
3   (msg:"Possible Port Scan"; \
4     flags:S; threshold:type threshold, \
5     track by_src, count 20, seconds 5; \
6     sid:1000001; rev:1;)
7
8 # Detect SSH brute-force
9 alert tcp any any -> $HOME_NET 22 \
10   (msg:"SSH Brute-force Attempt"; \
11     threshold:type both, track by_src, \
12     count 5, seconds 60; \
13     sid:1000002; rev:1;)
```

Phụ lục D

Lệnh test tấn công

Listing D.1: Các lệnh kiểm thử tấn công

```
1 # Port Scanning with Nmap
2 nmap -sS -O TARGET_IP
3 nmap -sV --script=default TARGET_IP
4
5 # SSH Brute-force with Hydra
6 hydra -l root -P /usr/share/wordlists/rockyou.txt \
7     ssh://TARGET_IP
8
9 # Web attack with Nikto
10 nikto -h http://TARGET_IP
```